

Apex BioLabs Ltd — Security questionnaire

Governance / GV-01

id: GV-01

section: Governance

question: Who owns information security?

vendor_answer: A designated security owner reports monthly to the board. The risk register is reviewed every quarter.

supporting_evidence_ref: data-protection-policy.md / Governance

Governance / GV-02

id: GV-02

section: Governance

question: How are policies approved?

vendor_answer: Policies are approved annually by the executive team and version controlled in a restricted repository.

supporting_evidence_ref: data-protection-policy.md / Governance

Governance / GV-03

id: GV-03

section: Governance

question: How are employees trained?

vendor_answer: All staff complete induction training and annual refresher training with completion tracked.

supporting_evidence_ref: data-protection-policy.md / Governance

Governance / GV-04

id: GV-04

section: Governance

question: How are risks tracked?

vendor_answer: Risks have named owners, target dates and documented review decisions.

supporting_evidence_ref: data-protection-policy.md / Governance

Access Control / AC-01

id: AC-01

section: Access Control

question: How are users provisioned?

vendor_answer: Accounts require a manager-approved ticket and role-based permissions. Production access requires separate approval.

supporting_evidence_ref: data-protection-policy.md / Access Control

Access Control / AC-02

id: AC-02

section: Access Control

question: Are privileged accounts reviewed?

vendor_answer: Privileged access is checked quarterly by application owners and approval records are retained.

supporting_evidence_ref: data-protection-policy.md / Access Control

Access Control / AC-03

id: AC-03

section: Access Control

question: Is MFA enforced for every administrator?

vendor_answer: MFA is enforced for all users and all administrative accounts, including remote access.

supporting_evidence_ref: data-protection-policy.md / Access Control

Access Control / AC-04

id: AC-04

section: Access Control

question: How are leavers removed?

vendor_answer: Leaver accounts are disabled within four hours of HR notification and tokens are revoked.

supporting_evidence_ref: data-protection-policy.md / Access Control

Access Control / AC-05

id: AC-05

section: Access Control

question: How is privileged access logged?

vendor_answer: Privileged actions are recorded in central logs retained for twelve months and reviewed weekly.

supporting_evidence_ref: data-protection-policy.md / Access Control

Data Protection / DP-01

id: DP-01

section: Data Protection

question: Where is customer data hosted?

vendor_answer: Customer data and backups are stored in Singapore and the United States.

supporting_evidence_ref: data-protection-policy.md / Data Protection

Data Protection / DP-02

id: DP-02

section: Data Protection

question: What transfer safeguards apply?

vendor_answer: No signed Standard Contractual Clauses or UK transfer addendum are currently in place.

supporting_evidence_ref: data-protection-policy.md / Data Protection

Data Protection / DP-03

id: DP-03

section: Data Protection

question: How are retention periods enforced?

vendor_answer: Retention schedules are agreed in the DPA and enforced through monthly automated deletion jobs.

supporting_evidence_ref: data-protection-policy.md / Data Protection

Data Protection / DP-04

id: DP-04

section: Data Protection

question: How are deletion requests verified?

vendor_answer: Deletion requests require tenant-owner approval and are supported by an audit record within thirty days.

supporting_evidence_ref: data-protection-policy.md / Data Protection

Data Protection / DP-05

id: DP-05

section: Data Protection

question: Are data roles documented?

vendor_answer: Data controller and processor roles are specified in the DPA with an agreed purpose and scope.

supporting_evidence_ref: data-protection-policy.md / Data Protection

Encryption / EN-01

id: EN-01

section: Encryption

question: How is data encrypted at rest?

vendor_answer: Customer data and backups use AES-256 encryption with tenant-scoped access to key services.

supporting_evidence_ref: data-protection-policy.md / Encryption

Encryption / EN-02

id: EN-02

section: Encryption

question: How is data protected in transit?

vendor_answer: TLS 1.2 or higher is enforced for client and internal service connections; legacy protocols are disabled.

supporting_evidence_ref: data-protection-policy.md / Encryption

Encryption / EN-03

id: EN-03

section: Encryption

question: How often are encryption keys rotated?

vendor_answer: Encryption keys are rotated every quarter with dual approval and logged changes.

supporting_evidence_ref: data-protection-policy.md / Encryption

Encryption / EN-04

id: EN-04

section: Encryption

question: Who can access key material?

vendor_answer: Key administration is limited to two named security engineers; key use and changes are centrally logged.

supporting_evidence_ref: data-protection-policy.md / Encryption

BC/DR / BC-01

id: BC-01

section: BC/DR

question: Is a disaster recovery exercise tested annually?

vendor_answer: The disaster recovery plan has never been tested. Recovery steps remain a draft.

supporting_evidence_ref: data-protection-policy.md / BC/DR

BC/DR / BC-02

id: BC-02

section: BC/DR

question: What is the recovery point objective?

vendor_answer: The recovery point objective is 24 hours. Daily snapshots are the only recovery mechanism.

supporting_evidence_ref: data-protection-policy.md / BC/DR

BC/DR / BC-03

id: BC-03

section: BC/DR

question: What is the recovery time objective?

vendor_answer: The recovery time objective is 48 hours, but it has not been validated through an exercise.

supporting_evidence_ref: data-protection-policy.md / BC/DR

BC/DR / BC-04

id: BC-04

section: BC/DR

question: How are backups protected?

vendor_answer: Backups are encrypted, isolated from production and checked weekly through restoration tests.

supporting_evidence_ref: data-protection-policy.md / BC/DR

BC/DR / BC-05

id: BC-05

section: BC/DR

question: How are test outcomes tracked?

vendor_answer: Exercise findings have owners and deadlines. Progress is reviewed monthly by the security committee.

supporting_evidence_ref: data-protection-policy.md / BC/DR

Incident Response / IR-01

id: IR-01

section: Incident Response

question: How are incidents detected?

vendor_answer: Alerts from endpoint, cloud and application logs are monitored continuously by the on-call security team.

supporting_evidence_ref: data-protection-policy.md / Incident Response

Incident Response / IR-02

id: IR-02

section: Incident Response

question: When are customers notified of a breach?

vendor_answer: Customers are notified within 24 hours of confirmation of a personal data breach.

supporting_evidence_ref: data-protection-policy.md / Incident Response

Incident Response / IR-03

id: IR-03

section: Incident Response

question: How are incidents escalated?

vendor_answer: Incidents are escalated to the incident commander, legal counsel and customer communications owner.

supporting_evidence_ref: data-protection-policy.md / Incident Response

Incident Response / IR-04

id: IR-04

section: Incident Response

question: How are lessons learned documented?

vendor_answer: Post-incident reviews occur within ten working days and track corrective actions to completion.

supporting_evidence_ref: data-protection-policy.md / Incident Response

Sub-processors / SP-01

id: SP-01

section: Sub-processors

question: Is a current subprocessor list maintained?

vendor_answer: The current subprocessor list includes provider purpose, location, data access and review status.

supporting_evidence_ref: data-protection-policy.md / Sub-processors

Sub-processors / SP-02

id: SP-02

section: Sub-processors

question: How are offshore support providers disclosed?

vendor_answer: All offshore support providers are disclosed in the subprocessor register before they receive access.

supporting_evidence_ref: data-protection-policy.md / Sub-processors

Sub-processors / SP-03

id: SP-03

section: Sub-processors

question: How are subprocessors assessed?

vendor_answer: Industry-standard controls are in place. Individual review records are not retained.

supporting_evidence_ref: data-protection-policy.md / Sub-processors

Sub-processors / SP-04

id: SP-04

section: Sub-processors

question: How are changes communicated?

vendor_answer: Customers receive thirty days' advance notice of subprocessor changes and may raise objections.

supporting_evidence_ref: data-protection-policy.md / Sub-processors

Compliance / CO-01

id: CO-01

section: Compliance

question: What certifications are held?

vendor_answer: A current SOC 2 Type II summary is available and audit evidence is shared under a confidentiality agreement.

supporting_evidence_ref: data-protection-policy.md / Compliance

Compliance / CO-02

id: CO-02

section: Compliance

question: When was the last penetration test?

vendor_answer: The last independent penetration test was completed 18 months ago. A new test has not been scheduled.

supporting_evidence_ref: data-protection-policy.md / Compliance

Compliance / CO-03

id: CO-03

section: Compliance

question: How are audit exceptions tracked?

vendor_answer: Audit exceptions are tracked in the risk register and independently checked before closure.

supporting_evidence_ref: data-protection-policy.md / Compliance

Compliance / CO-04

id: CO-04

section: Compliance

question: How are contract commitments reviewed?

vendor_answer: The legal owner reviews breach notice, retention, audit rights and transfer requirements before contracting.

supporting_evidence_ref: data-protection-policy.md / Compliance

Compliance / CO-05

id: CO-05

section: Compliance

question: How is evidence shared?

vendor_answer: Evidence is available through a controlled review process with named document owners and dates.

supporting_evidence_ref: data-protection-policy.md / Compliance